

Cyber Threat Intelligence

Executive Briefing

Report Date: July 05, 2026

Generated: 2026-07-05 22:30 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	10	5	1	20

2. Executive Summary

As of July 05, 2026, the security operations center has concluded the analysis of 20 total vulnerabilities, categorized as 4 Critical, 10 High, 5 Medium, and 1 Low severity findings. This volume of critical-tier exposure represents a High to Critical organizational risk posture, necessitating immediate remediation to maintain internal integrity. The foremost priority is CVE-2026-49352, Authentication Bypass via Default JWT Secret, as this flaw permits total authentication subversion and poses the most immediate threat to our infrastructure. The executive leadership team is advised to adopt an aggressive emergency patch deployment posture to neutralize these exposures before they can be weaponized by threat actors. Failure to act within the mandated timeframes will result in an unacceptable increase in our surface area for potential adversarial exploitation.

3. Critical Action List

1. Immediate: Patch CVE-2026-49352 (Authentication Bypass via Default JWT Secret) within 24 hours to prevent unauthorized session escalation.
2. Immediate: Remediate CVE-2026-54617 (Path Traversal in LaunchServer File Handler) within 24 hours to mitigate unauthorized remote file system access.
3. High Priority: Deploy hotfixes for CVE-2026-52830 (Telegram Session Protection Bypass) within 48 hours to secure bearer token handling mechanisms.
4. High Priority: Implement Host header validation for CVE-2026-50194 (Management Port Isolation Bypass in Steeltoe) within 72 hours.
5. High Priority: Disable vulnerable Recce server SQL execution pathways for CVE-2026-49360 within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-49352	Authentication Bypass via Default...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Path Traversal in LaunchServer Fi...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Telegram Session Protection Bypas...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Management Port Isolation Bypass ...	8.2	High	74/100	CWE-288
CVE-2026-49360	Unauthorized SQL Execution in Rec...	9.1	Critical	73/100	CWE-73
CVE-2026-2092	Improper Validation of Encrypted ...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Local Access Gate Bypass via Head...	7.5	High	68/100	CWE-290
CVE-2026-46599	Denial of Service in TIFF Decompr...	7.5	High	68/100	CWE-770
CVE-2026-52792	Source Code Disclosure in Algerno...	7.5	High	68/100	CWE-69
CVE-2026-50200	Exposure of Database Passwords in...	7.5	High	68/100	CWE-200
CVE-2026-50196	Registry Poisoning in Steeltoe Eu...	7.5	High	68/100	CWE-20
CVE-2026-49289	Denial of Service via XPath Trans...	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Misbehavior in Zebra Addr...	7.5	High	68/100	CWE-617
CVE-2026-52834	Integer Overflow in jxl-grid on 3...	7.3	High	66/100	CWE-122
CVE-2026-49284	Insecure SAML Response Validation...	6.8	Medium	64/100	CWE-345
CVE-2026-50201	Insecure Permission Requirement f...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	Insecure JWKS Cache Sharing in St...	5.9	Medium	53/100	CWE-668
CVE-2026-50267	Unprotected Private Key Storage i...	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Post-Initialization Exposure of S...	6.5	Medium	39/100	CWE-862
CVE-2026-50268	Insecure Padding Selection in Ste...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49352

Finding: Authentication Bypass via Default JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router software utilizes a hardcoded, default fallback secret for JWT validation, which allows for total authentication bypass. This security oversight occurs because the application fails to enforce the configuration of a unique production secret key upon deployment. Unauthorized actors can forge valid authentication tokens to impersonate any user,

including administrative accounts.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the default JWT secret through public documentation or reverse engineering. The attacker generates a signed JWT token using this key, specifying administrator privileges in the payload claims. The attacker then sends this token in the Authorization header to the application's protected API endpoints. The server accepts the forged token as legitimate, granting the attacker full administrative access.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Path Traversal in LaunchServer File Handler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The LaunchServer FileServerHandler contains a path traversal vulnerability due to insufficient sanitization of input directory parameters. By submitting crafted file paths containing sequence modifiers, an attacker can escape the intended root directory. This vulnerability grants the attacker unauthorized access to sensitive files residing outside the intended file server scope.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the FileServerHandler endpoint using directory traversal sequences (e.g., ../../etc/passwd). The application fails to resolve or filter these sequences before passing the path to the underlying OS file handler. The system serves the contents of the requested sensitive file to the attacker's client. This allows for unauthorized disclosure of critical system data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Telegram Session Protection Bypass via Path Traversal

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram component suffers from a path traversal vulnerability within its bearer token handling mechanism. This flaw occurs because the library fails to sanitize token inputs that are used to generate session storage paths. An attacker can manipulate these inputs to access or overwrite reserved Telegram session files, bypassing authorization protections.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Telegram gateway API using a maliciously formatted Bearer token string containing path traversal characters. The backend application uses this token as a direct file system identifier for session lookups. The server resolves the path outside the intended scope, accessing or corrupting sensitive session files. This leads to complete takeover of existing Telegram sessions and administrative system compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Management Port Isolation Bypass in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe is vulnerable to management-port isolation bypass via spoofed Host headers. The internal routing logic erroneously trusts the Host header provided by incoming traffic to determine whether a request is destined for the management port. This allows an external attacker to interact with internal-only management endpoints from the public network.

Proof of Concept (PoC):

An attacker sends a request to the application's primary port with a Host header set to the address of the internal management network. The Steeltoe routing logic processes the header and erroneously directs the request to the management interface. The attacker then interacts with sensitive actuators typically hidden from public traffic. This results in unauthorized access to restricted application data and system status.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-49360

Finding: Unauthorized SQL Execution in Recce Server

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 73/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Recce server fails to validate authentication before allowing SQL execution commands via DuckDB interactions. This flaw exists because the backend handler trusts unauthenticated user input when interfacing with the database engine. Attackers can leverage this to gain local file read and write access, compromising system-level data.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted SQL query string to the Recce server management endpoint. The server interface interprets the command through DuckDB without verifying the origin of the request. This allows the attacker to execute arbitrary file operations on the host filesystem. The attacker successfully gains read/write capabilities for sensitive system files.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-2092

Finding: Improper Validation of Encrypted SAML Assertions

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Keycloak fails to correctly validate encrypted SAML assertions, leading to unauthorized access. The root cause is a lack of stringent integrity verification on the decrypted content before it is parsed by the application security context. This allows an attacker to bypass authentication mechanisms by submitting manipulated or improperly decrypted assertion payloads.

Proof of Concept (PoC):

An authenticated user with low privileges captures their own encrypted SAML assertion. The attacker modifies the content and re-encrypts it to match expected parameters, then presents it to the Keycloak authentication endpoint. The server decrypts the assertion and trusts the underlying malicious claims without verifying the integrity of the original source. This results in unauthorized escalation of privileges within the Keycloak instance.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Local Access Gate Bypass via Header Spoofing

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The 9router appliance implements an incomplete fix for local-only access controls, permitting bypasses via Host header manipulation. This vulnerability arises because the authentication middleware trusts the Host header to verify internal routing origin. Remote attackers can spoof these headers to access restricted management interfaces reserved for local loopback connections.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates an HTTP request to the target 9router appliance. The attacker modifies the Host header to '127.0.0.1' while sending the request to the external interface. The routing engine erroneously identifies the connection as local, bypassing authorization logic for the internal gateway. This grants the attacker full access to restricted administrative configuration pages.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Denial of Service in TIFF Decompression

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	None
Availability Impact	High

Description:

The `golang.org/x/image/tiff` package experiences excessive resource consumption during the PackBits decompression routine. This occurs because the decompressor fails to impose strict bounds on memory allocation for variable-length encoded input streams. Attackers can provide a malicious TIFF file to exhaust system memory and trigger a service-wide crash.

Proof of Concept (PoC):

An unauthenticated attacker uploads a maliciously crafted TIFF file to an endpoint that processes image metadata. The application calls the PackBits decompression function to parse the image structure. The function triggers a large memory allocation request that exceeds available heap capacity during processing. The system becomes unresponsive or terminates due to out-of-memory errors.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792

Finding: Source Code Disclosure in Algernon via NTFS

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1046

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon server allows server-side script source disclosure on Windows operating systems by exploiting specific NTFS filename handling. The root cause is a failure to properly canonicalize file paths, allowing direct access to script files that should be executed rather than served. This exposure reveals proprietary code and sensitive configuration details to remote visitors.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a script file location within the Algernon web root on a Windows host. The attacker submits a specially formatted request utilizing NTFS stream or short filename syntax that the server fails to interpret as an executable script. The server bypasses the execution logic and treats the file as static content, returning the raw source code. The attacker now has full read access to the application's business logic.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200

Finding: Exposure of Database Passwords in Steeltoe Logs

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter embedded database passwords within connection strings before they are logged or exposed. This occurs because the sanitizer logic does not account for the diverse formats in which sensitive connection information can be presented. This vulnerability allows any attacker with access to the logs to capture administrative credentials.

Proof of Concept (PoC):

An attacker gains access to the log aggregation interface for a Steeltoe-based application. By querying the logs for string patterns related to connection strings, the attacker locates plaintext passwords previously output by the env actuator. The sanitizer routine failed to identify the specific key-value structure of the database URL. The attacker uses these credentials to establish a direct connection to the backend database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Poisoning in Steeltoe Eureka Discovery

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

Steeltoe.Discovery.Eureka is vulnerable to registry poisoning when an unrecognized DataCenterInfo.Name is provided by a malicious service instance. The server fails to safely ignore or sanitize the malformed data before merging it into the global service registry. An attacker can exploit this to trigger a Denial of Service across the entire discovery fabric.

Proof of Concept (PoC):

An attacker stands up a rogue microservice and registers it with the Eureka server using a crafted DataCenterInfo.Name string designed to break parsing logic. The Eureka server receives the registration request and attempts to merge this

metadata into the global state. The parser fails, causing the service discovery process to crash or enter an invalid state. All downstream services fail to discover their dependencies, resulting in a systemic outage.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: Denial of Service via XPath Transform

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

SimpleSAMLphp is susceptible to Denial of Service (DoS) attacks via complex XPath transformations in incoming SAML messages. The underlying parser does not impose recursive limits on XPath query evaluation, allowing an attacker to exhaust CPU resources. This vulnerability can be triggered remotely with a relatively small, specially crafted payload.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an XML document containing a highly nested and repetitive XPath expression to the SAML consumption endpoint. The server attempts to evaluate the path using the vulnerable transformation engine. The computation consumes 100% of the allocated worker process CPU for an extended period. Repeated requests lead to resource exhaustion and complete service unavailability.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Misbehavior in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The Zebra Address Book is prone to application failure due to improper memory handling when processing IPv4-mapped addresses within its mempool. The logic fails to differentiate between address types during block allocation, leading to inconsistent state and assertion failures. This condition crashes the service whenever an attacker triggers specific address parsing flows.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a network request containing a specially formatted IPv4-mapped IPv6 address to the address book service. The service attempts to normalize the address within the mempool, triggering a violation of an internal consistency assertion. The application immediately aborts processing to prevent corruption, effectively crashing the service. This attack can be repeated to maintain persistent denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834

Finding: Integer Overflow in jxl-grid on 32-bit

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	Low

Description:

The jxl-grid library contains an integer overflow flaw on 32-bit architectures during grid calculation routines. This occurs because the library does not validate the result of arithmetic operations against the maximum pointer size before performing heap allocation. Attackers can exploit this to perform an out-of-bounds write to heap memory, potentially leading to arbitrary code execution.

Proof of Concept (PoC):

An unauthenticated remote attacker provides a malformed image input to a system using the jxl-grid library. The library performs a multiplication of grid dimensions that overflows a 32-bit integer, resulting in a tiny allocation for a massive dataset. The application writes subsequent data outside the allocated heap boundary. This corruption disrupts service and provides a potential vector for code injection.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: Insecure SAML Response Validation in SimpleSAMLphp

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

The SimpleSAMLphp Service Provider incorrectly validates SAML responses when an unsigned Response/InResponseTo is paired with a signed assertion lacking specific SubjectConfirmationData checks. This logic flaw permits an attacker to inject responses from an unexpected Identity Provider. Successful exploitation allows for unauthorized account assertion and session hijacking.

Proof of Concept (PoC):

An attacker creates a malicious SAML response from an unauthorized IdP and redirects a victim user to the SimpleSAMLphp SP endpoint. The SP logic validates the signed assertion but fails to verify the binding between the `InResponseTo` fields in the response and the assertion. The application treats the forged assertion as valid for the victim's session. The attacker successfully hijacks the victim's authenticated session.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Insecure Permission Requirement for Steeltoe Actuators

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe exposes sensitive management actuators, such as heapdump and env, requiring only low-level 'Restricted' permissions. This configuration oversight fails to implement the principle of least privilege, leaving internal state data accessible to low-level accounts. Unauthorized actors can exploit these endpoints to extract internal runtime secrets or memory contents.

Proof of Concept (PoC):

An attacker logs into the application using a legitimate, low-privilege 'Restricted' account. The attacker browses to the management actuator endpoint (/actuator/heapdump) and initiates a download request. The application verifies the user's role, finds it sufficient, and serves a full snapshot of the server's heap memory. The attacker analyzes this snapshot to recover embedded database credentials and private configuration keys.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: Insecure JWKS Cache Sharing in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's static JSON Web Key Set (JWKS) cache is shared across different security schemes and fails to implement proper invalidation. This vulnerability stems from the application's failure to isolate cryptographic key sets according to their specific trust domains. An attacker can exploit this to reuse or pollute the cache, potentially causing authorization failures or session bypasses.

Proof of Concept (PoC):

An administrative user who has compromised one application scheme targets the shared JWKS cache used by Steeltoe. The attacker forces the cache to load a malicious key set meant for a different security domain. The application subsequently trusts the attacker's key set when verifying requests for the entire system. This leads to the cross-scheme authentication bypass and systemic trust compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-50267

Finding: Unprotected Private Key Storage in Steeltoe

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe writes TLS private keys to the /tmp directory with world-readable default permissions and fails to perform

cleanup. This occurs due to inadequate management of temporary file lifecycle and missing umask restrictions on sensitive key artifacts. Any local user on the host system can read these keys, leading to potential traffic decryption.

Proof of Concept (PoC):

A local attacker with low privileges probes the /tmp directory during the Steeltoe application startup process. The attacker locates a freshly written TLS private key file before the application can delete it. The file permissions allow the attacker to read the contents of the key file directly. With this key, the attacker can decrypt historical and ongoing network traffic associated with the server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Post-Initialization Exposure of Setup Page

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

Kiwi TCMS continues to render and respond to requests via the /init-db/ page after the initial database setup is complete. The failure to disable this diagnostic endpoint allows any user to reach state-changing operations intended for one-time initialization. This exposure risks unauthorized database manipulation if the endpoint remains accessible in production environments.

Proof of Concept (PoC):

An unauthenticated remote attacker navigates to the /init-db/ endpoint on an already configured Kiwi TCMS instance. The application logic fails to check for an existing installation flag before responding to the GET request. The attacker is presented with an initialization form that interacts with the live database. This allows the attacker to trigger unexpected database state modifications.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Insecure Padding Selection in Steeltoe OAEP

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Steeltoe framework incorrectly defaults to PKCS#1 v1.5 padding even when OAEP (Optimal Asymmetric Encryption Padding) is requested. This silent downgrade occurs because the internal security configuration mapping improperly prioritizes older legacy standards. This renders cryptographic operations vulnerable to padding oracle attacks if an attacker intercepts sensitive data.

Proof of Concept (PoC):

A local attacker with high privileges identifies that Steeltoe uses legacy padding despite configuration. The attacker intercepts a series of encrypted application messages and monitors responses for potential padding oracle errors. By analyzing the timing differences in error responses, the attacker decrypts targeted ciphertexts bit by bit. This enables the eventual extraction of sensitive secrets stored within the application's configuration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>

- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>